

Chapitre 5

La communication des risques

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Destinataires du reporting, strates et règles d'un reporting utile

- (a) Le cours identifie six catégories de destinataires du reporting de risque opérationnel : « le comité des risques du conseil d'administration (supervision stratégique), le comité de direction (arbitrages opérationnels), la fonction centrale de gestion du risque opérationnel (coordination et agrégation), les responsables métiers et champions du risque dans les lignes d'activité (gestion quotidienne), le comité d'audit (assurance indépendante), et enfin les destinataires externes – régulateurs et public ». Pour chacune de ces six catégories, préciser en une phrase ce qui distingue son besoin d'information des cinq autres, à partir du rôle donné entre parenthèses par le cours.
- (b) Le cours modélise le reporting comme un « gâteau » à trois strates : « à la base, un reporting très détaillé sert à surveiller l'activité au quotidien (niveau opérationnel). Au milieu, un reporting agrégé permet d'agir – ajuster des contrôles, lancer des plans d'action (niveau management). Au sommet, un reporting synthétique, très sélectif, permet de décider des orientations stratégiques (niveau conseil d'administration) », le cours précisant que « plus on monte dans les strates, moins le volume d'information est important, mais plus son niveau d'agrégation et sa portée stratégique augmentent ». Expliquer pourquoi cette relation inverse entre volume et portée stratégique est une nécessité plutôt qu'un simple choix de présentation : que se passerait-il concrètement si le conseil d'administration recevait le même volume d'information que le niveau opérationnel ?
- (c) Le cours illustre les trois strates par un même événement décliné trois fois : « un incident de fraude interne isolé remonte en détail dans le reporting opérationnel du service concerné. Agrégé avec d'autres incidents similaires sur le trimestre, il alimente une tendance présentée au comité de direction. S'il révèle une faiblesse structurelle de contrôle affectant l'appétit pour le risque de l'organisation, seule sa conclusion – et non chaque occurrence – remonte au conseil d'administration ». Expliquer précisément la condition qui déclenche le passage de la deuxième à la troisième strate dans cet exemple : pourquoi un incident isolé, même grave, ne suffit-il pas à lui seul à justifier une remontée au conseil, alors qu'une faiblesse structurelle révélée par plusieurs incidents agrégés le justifie ?
- (d) Le cours pose trois règles pour un reporting de valeur : le « coût de production » de l'information mis en balance avec son bénéfice, l'alignement de chaque élément sur « une finalité claire – à qui sert-il, et pour quelle décision ? », et l'exigence qu'un bon reporting « influence une décision », sans quoi « il est superflu, quelle que soit sa qualité technique ». En utilisant ces trois règles, expliquer pourquoi un même tableau détaillé d'indicateurs opérationnels, parfaitement légitime dans le reporting du niveau surveiller destiné aux équipes, deviendrait un manquement aux trois règles s'il était transmis tel quel, sans synthèse, au conseil d'administration.

Exercice 2 — Les sept composantes d'un reporting complet

- (a) Le cours identifie sept composantes d'un reporting complet : « (1) le top 10 des risques, une liste hiérarchisée des risques les plus significatifs; (2) la cartographie thermique (heatmap) et le registre des risques, qui visualisent probabilité et impact; (3) les métriques d'appétit pour le risque, qui situent l'exposition actuelle par rapport aux limites fixées; (4) les indicateurs clés de risque (KRI) et le suivi des problèmes (issues) ouverts; (5) les incidents et quasi-incidents (near misses); (6) les plans d'action correctifs et préventifs; et (7) les risques émergents, identifiés par une veille prospective (horizon scanning) ». Le cours ajoute que le modèle du top 10 « contraint l'organisation à hiérarchiser explicitement ses risques opérationnels les plus significatifs plutôt que de les présenter comme une liste plate », tandis que le registre des risques détaillé « reste la référence exhaustive pour les équipes opérationnelles ». Le top 10, la cartographie thermique et le registre portent-ils sur une information différente, ou sur la même information présentée à des niveaux de détail décroissants ? Justifier précisément à partir de ces deux citations, et relier la réponse à la structure en trois strates de l'exercice 1(b).

- (b) Le cours distingue « les indicateurs clés de risque (KRI) [qui] mesurent l'évolution d'une exposition au risque (par exemple, le nombre de transactions en attente de validation manuelle); les indicateurs clés de performance (KPI) [qui] mesurent l'efficacité opérationnelle d'un processus; les indicateurs clés de contrôle (KCI) [qui] mesurent la robustesse d'un contrôle donné (taux de complétion des vérifications obligatoires, par exemple) ». L'étude de cas du cours décrit un établissement bancaire qui « construit un tableau de bord trimestriel de dix KRI [...], chacun assorti de trois seuils (vert, orange, rouge) calibrés sur les données historiques et l'appétit pour le risque du conseil. Le franchissement d'un seuil orange déclenche une investigation par le second niveau de contrôle; un seuil rouge déclenche une escalade automatique au comité des risques, indépendamment du calendrier normal de reporting ». Pourquoi le cours conclut-il cet exemple en affirmant que « la communication du risque ne doit pas être purement périodique mais aussi événementielle » ? Qu'est-ce qui, dans le mécanisme de seuil rouge décrit, rend cette communication événementielle plutôt que périodique ?
- (c) Distinguer précisément un « problème » (issue), un « incident », et un « quasi-incident » (near miss) à partir des définitions du cours : « un problème (issue) désigne une faiblesse identifiée dans un contrôle ou un processus, avant toute matérialisation en perte [...]. Un incident est la matérialisation effective d'un risque opérationnel, avec ou sans perte financière. Un quasi-incident (near miss) est un événement qui aurait pu causer une perte mais qui [...] ne l'a pas fait ». Pourquoi le cours qualifie-t-il les quasi-incidents de « source d'apprentissage aussi précieuse que les pertes réelles, souvent sous-exploitée » : qu'est-ce qui, structurellement, rend leur remontée plus difficile à obtenir que celle d'un incident avéré ?
- (d) Le cours indique que « de nombreuses organisations font du nombre de plans d'action en retard un indicateur de discipline à part entière – une forme de objectif zéro sur les échéances non tenues – car un plan d'action qui traîne indéfiniment signale un problème de gouvernance aussi grave que le risque qu'il était censé traiter ». Expliquer pourquoi un plan d'action correctif en retard constitue un problème de gouvernance *distinct* du risque opérationnel initial qu'il visait à traiter, plutôt qu'une simple prolongation de ce même risque. Par ailleurs, le cours qualifie la veille prospective (horizon scanning) de composante qui « alimente directement l'étape d'identification du cycle de gestion des risques (chapitre 2) », à la différence des autres composantes qui « regardent en arrière ou constatent le présent ». En quoi cette composante crée-t-elle une boucle entre le reporting (ce chapitre) et l'identification (chapitre 2), alors que les autres composantes n'alimentent, en apparence, que le reporting lui-même ?

Exercice 3 — Les défis statistiques du reporting, l'agrégation qualitative et l'assurance externe

- (a) Le cours indique : « les données de l'industrie (base ORX) [...] : les pertes les plus importantes, supérieures à 10 millions d'euros, ne représentent que 0,4 % du nombre d'occurrences mais concentrent 66,6 % de la sévérité totale ». Calculer le rapport entre la part de sévérité (66,6 %) et la part du nombre d'occurrences (0,4 %) que représentent ces pertes extrêmes. Expliquer en quoi ce rapport, à lui seul, justifie la conclusion du cours selon laquelle « il n'y a pas de moyennes pertinentes en risque opérationnel ».
- (b) Le cours tire de ce constat une conséquence précise pour la forme du reporting : « privilégier les distributions, les percentiles et les événements extrêmes plutôt que les indicateurs de tendance centrale, et toujours accompagner un chiffre agrégé d'une mention de sa dispersion sous-jacente ». En quoi un reporting qui se contenterait de communiquer la perte opérationnelle moyenne de l'année au conseil d'administration, sans autre précision, violerait-il directement cette recommandation ? Proposer, à partir des seules notions employées dans cette citation, ce que ce reporting devrait présenter à la place ou en complément.
- (c) Le cours propose trois méthodes pour agréger des risques documentés qualitativement : « la conversion en équivalent monétaire [...]; la catégorisation en paliers (par exemple des graphiques en chandelier associant une échelle de couleurs à des tranches de sévérité); et l'approche du pire cas plausible, qui retient le scénario le plus défavorable raisonnablement envisageable plutôt qu'une moyenne pondérée ». L'étude de cas correspondante décrit une

banque qui combine, dans une seule cartographie thermique, des risques quantitatifs (pertes historiques, VaR) et des risques RCSA « convertis en équivalents monétaires à l'aide de barèmes internes validés par le second niveau de contrôle », une combinaison qui permet « une vue unique et comparable, au prix d'une perte de granularité que le conseil accepte en échange de la lisibilité ». Pourquoi la méthode du pire cas plausible serait-elle, par construction, moins compatible avec cet objectif de « vue unique et comparable » que la conversion en équivalent monétaire effectivement retenue par la banque de l'étude de cas ?

- (d) Le cours définit l'assurance combinée comme « la coordination des travaux des trois lignes de défense [...] afin d'éviter les doublons, de combler les angles morts et de fournir au conseil une vision unique et cohérente [...], plutôt que trois rapports disjoints et parfois contradictoires », et détaille le Pilier 3 de Bâle comme imposant « une information qualitative sur la gouvernance [...]; l'historique des pertes opérationnelles [...]; et le détail de l'indicateur d'exploitation (business indicator) ». Le cas Credit Suisse (rapport annuel 2021) est présenté comme montrant que « la communication externe du risque opérationnel peut devenir un enjeu de crédibilité et de réputation à part entière, distinct du dispositif de gestion interne qu'elle documente ». En quoi l'assurance combinée (une coordination *interne* entre les trois lignes de défense) et le Pilier 3 (une divulgation *externe* au marché) poursuivent-ils, chacun à son niveau, un même objectif de cohérence d'une vision unique du risque – et pourquoi ce même objectif de cohérence devient-il, pour le Pilier 3 uniquement, un enjeu de crédibilité et de réputation plutôt qu'un simple enjeu de gouvernance interne ?

2 Exercice cumulatif (chapitres 5, 4, 3, 2, 1)

Exercice 4 — La communication des risques à la lumière des quatre chapitres précédents

- (a) Le chapitre 4 distingue quatre types de contrôles – « préventifs [...], détectifs [...], correctifs [...], et directifs [...] » – et quatre niveaux de rigueur croissante pour les tester, de « l'auto-certification (ou enquête déclarative) [qui] offre l'assurance la plus faible » jusqu'à « la reperformance – reproduire le contrôle sur un échantillon et comparer les résultats [...] – [qui] constitue la forme de test la plus exigeante ». Ce chapitre définit les indicateurs clés de contrôle (KCI) comme ceux qui « mesurent la robustesse d'un contrôle donné (taux de complétion des vérifications obligatoires, par exemple) », et rapporte que « de nombreuses organisations font du nombre de plans d'action en retard un indicateur de discipline à part entière [...] car un plan d'action qui traîne indéfiniment signale un problème de gouvernance aussi grave que le risque qu'il était censé traiter ». Montrer que le KCI et le suivi des plans d'action de ce chapitre forment, ensemble, le *canal de reporting* par lequel les résultats des tests de contrôle du chapitre 4 – en particulier ceux obtenus par reperformance, la forme de test la plus exigeante – deviennent visibles et actionnables pour le management, alors que le chapitre 4 se contente de définir la rigueur des tests eux-mêmes sans indiquer comment leurs résultats remontent ensuite dans l'organisation. Le chapitre 4 illustre, par le cas Knight Capital, une défaillance résultant en partie de « l'absence de hiérarchisation des alertes, et [de] l'absence de procédure d'urgence ». En quoi cette défaillance de 2012 est-elle exactement celle que l'objectif zéro sur les plans d'action en retard de ce chapitre, combiné aux seuils rouges d'escalade automatique de sa cartographie thermique, est conçu pour prévenir ?
- (b) Le chapitre 3 définit déjà le trio « KPI [...] mesurent l'atteinte d'objectifs opérationnels [...] KRI [...] signalent l'évolution de la probabilité ou de l'impact d'un risque [...] KCI [...] mesurent l'efficacité de conception ou de fonctionnement des contrôles [...] ces trois familles se recoupent largement », ainsi que le code couleur de la carte de chaleur – « vert (dans l'appétit, surveillance de routine) [...] rouge (bien au-delà de l'appétit, action urgente requise) ». Ce chapitre reprend très exactement ce même trio d'indicateurs et cette même cartographie, mais au moment où ils quittent l'atelier de mesure pour devenir un objet de communication : le tableau de bord trimestriel de dix KRI de l'étude de cas de ce chapitre, avec ses « trois seuils (vert, orange, rouge) calibrés sur les données historiques et l'appétit pour le risque du conseil », est un déploiement

direct, à fréquence régulière et à destinataires définis, des mêmes indicateurs et du même code couleur que le chapitre 3 se contentait de définir analytiquement. Montrer précisément ce que ce chapitre ajoute au chapitre 3 sur ce point : le chapitre 3 répond à la question de savoir comment mesurer, ce chapitre répond à celle de savoir à qui, à quelle fréquence, et avec quelle conséquence de gouvernance (investigation, escalade) transmettre cette mesure. Par ailleurs, le chapitre 3 modélise la sévérité des pertes opérationnelles par la LDA comme une « distribution continue, asymétrique et à queue épaisse », le capital économique correspondant au « 99,9^e centile » de la distribution agrégée. Ce chapitre tire de ce même fait statistique – illustré cette fois par les données ORX (pertes de plus de 10 millions d’euros : « 0,4 % du nombre d’occurrences [...] 66,6 % de la sévérité totale ») – sa propre conclusion pour le reporting : « il n’y a pas de moyennes pertinentes en risque opérationnel », d’où la recommandation de « privilégier les distributions, les percentiles [...] plutôt que les indicateurs de tendance centrale ». Montrer que cette recommandation de ce chapitre n’est pas une observation statistique nouvelle, mais la traduction, en termes de présentation de l’information, d’une propriété de la distribution des pertes que le chapitre 3 avait déjà établie par la modélisation : sans la queue épaisse démontrée au chapitre 3, la mise en garde de ce chapitre contre les moyennes n’aurait aucun fondement quantitatif.

- (c) Le chapitre 2 anticipe déjà, dans sa propre synthèse de l’inventaire des risques, l’une des sept composantes de ce chapitre : « le top-dix des risques est la synthèse des combinaisons de probabilité et d’impact les plus significatives, rapportée au moins trimestriellement au comité exécutif ». Ce chapitre reprend cette même composante presque mot pour mot – « le top 10 des risques, une liste hiérarchisée des risques les plus significatifs » – en la replaçant dans l’ensemble plus large des sept composantes du reporting et des trois strates de destinataires. Montrer que le chapitre 2 avait donc déjà, sans le nommer comme tel, situé le top 10 comme un produit du cycle de gestion des risques que ce chapitre se contente de développer et de replacer dans son contexte de destinataire (comité exécutif) et de fréquence (trimestrielle) – une fréquence que le chapitre 2 précisait déjà et que ce chapitre reprend sans la modifier. Par ailleurs, le chapitre 2 définit le quasi-incident (near miss) comme « un événement qui aurait pu générer une perte opérationnelle mais qui [...] ne l’a pas fait [...] leur remontée n’est possible que dans un environnement de culture du risque sain, sans blâme injustifié », une définition que ce chapitre reprend en la qualifiant de « source d’apprentissage aussi précieuse que les pertes réelles, souvent sous-exploitée ». Ce chapitre ajoute-t-il un mécanisme concret qui répond à la difficulté, déjà identifiée au chapitre 2, de faire remonter les quasi-incidents sans une culture adéquate, ou se contente-t-il de répéter le même constat sous une autre formulation ? Justifier à partir de ce que ce chapitre dit – ou ne dit pas – sur le *mécanisme* de remontée des quasi-incidents, par contraste avec le chapitre 2 qui n’en précise que la *condition culturelle*. Enfin, ce chapitre affirme que la veille prospective (horizon scanning) « alimente directement l’étape d’identification du cycle de gestion des risques (chapitre 2) », alors que le chapitre 2 avait défini le PESTLE comme l’outil qui « structure le balayage de l’horizon (horizon scanning) pour repérer les risques émergents ». Montrer que ces deux chapitres décrivent en réalité une boucle fermée plutôt qu’une relation à sens unique : le chapitre 2 fournit l’outil qui produit les risques émergents identifiés, tandis que ce chapitre les fait remonter comme septième composante du reporting – avant que cette même composante, une fois communiquée, ne reparte alimenter une nouvelle itération de l’identification du chapitre 2. En quel sens le reporting de ce chapitre n’est-il donc pas seulement la dernière étape apparente du cycle de gestion des risques, mais aussi, pour sa septième composante uniquement, l’une de ses origines ?
- (d) Le chapitre 1 organise la gouvernance en une pyramide de comités – « à la base, des comités par activité ou zone géographique [...] au niveau intermédiaire, le comité groupe de risque opérationnel [...] au sommet, le comité risques créé par le conseil d’administration » – et en trois lignes de défense, où « la première ligne de défense [...] regroupe le personnel opérationnel et commercial [...] la deuxième ligne est la fonction indépendante de gestion du risque opérationnel (CORF) [...] la troisième ligne est l’audit interne, qui fournit une assurance indépendante ». Montrer que les six catégories de destinataires du reporting posées par ce chapitre à l’exercice 1(a) – responsables métiers/champions du risque, fonction centrale, comité de direction, comité

des risques du conseil, comité d'audit, destinataires externes – se superposent presque terme à terme à cette pyramide de comités et à ce modèle en trois lignes du chapitre 1 : identifier précisément, pour chacune des trois lignes de défense du chapitre 1, la ou les catégories de destinataires de ce chapitre qui lui correspondent. Ce chapitre définit par ailleurs l'assurance combinée comme la coordination des trois lignes de défense « afin d'éviter les doublons [...] et de fournir au conseil une vision unique et cohérente [...], plutôt que trois rapports disjoints » : en quoi ce mécanisme répond-il à une tension déjà implicite dans le modèle des trois lignes du chapitre 1, entre l'indépendance de chaque ligne – nécessaire à la valeur de son assurance propre – et la cohérence de la vision d'ensemble qu'elles doivent, prises ensemble, produire pour le conseil ? Le chapitre 1 définit enfin l'appétit pour le risque comme devant se décliner « en limites d'exposition, en exigences minimales de contrôle, et en seuils de fréquence et de sévérité des incidents tolérés – surveillés par des indicateurs clés de risque (KRI d'appétit) », et pose la transparence – « publication de l'approche et des expositions » – comme l'un des quatre axes des douze principes de la RPSMOR. Montrer que les seuils vert/orange/rouge du tableau de bord de KRI de ce chapitre sont l'instrument concret par lequel l'appétit pour le risque du chapitre 1 devient opérationnel et surveillable au quotidien, et que le Pilier 3 de ce chapitre est, de façon symétrique, l'instrument concret par lequel le principe de transparence de la RPSMOR du chapitre 1 devient une obligation de publication périodique effective plutôt qu'un simple principe déclaratif.

3 Applications en sciences économiques

Exercice 5 — Un tableau de bord de KRI trimestriel, ses seuils d'alerte, et l'effet de la queue épaisse des pertes, chiffrés

Une banque suit six indicateurs clés de risque (KRI) sur le trimestre. Chaque KRI est associé à un seuil vert (valeur inférieure ou égale au seuil = zone verte), à un seuil orange (valeur supérieure au seuil vert mais inférieure ou égale au seuil orange = zone orange), toute valeur au-delà du seuil orange plaçant le KRI en zone rouge :

KRI	Valeur trimestrielle	Seuil vert	Seuil orange
1. Transactions en attente de validation manuelle (unités)	145	100	180
2. Taux de rotation du personnel clé (%)	18	10	20
3. Incidents de fraude interne détectés (nombre/trimestre)	7	3	6
4. Indisponibilité des systèmes critiques (heures/trimestre)	1,5	2	6
5. Plaintes clients non résolues sous 5 jours ouvrés (nombre)	12	15	25
6. Plans d'action correctifs en retard (nombre, objectif zéro)	5	0	2

Par ailleurs, sur l'année écoulée, la banque a enregistré 2 500 événements de pertes opérationnelles pour une sévérité agrégée totale de 340 millions d'euros. Parmi ces événements, 9 ont dépassé individuellement 10 millions d'euros de perte, pour une sévérité cumulée de 225 millions d'euros sur ces seuls 9 événements. Une simulation de Monte-Carlo de la distribution agrégée des pertes annuelles produit par ailleurs les centiles suivants (en millions d'euros) : médiane (50^e centile) 300 ; 95^e centile 410 ; 99^e centile 520 ; 99,9^e centile (capital économique) 890.

- Classer chacun des six KRI en zone verte, orange ou rouge, et donner le nombre de KRI dans chaque zone. Selon le cours, quelle action est déclenchée pour chaque KRI en zone orange, et quelle action est déclenchée pour chaque KRI en zone rouge ?
- Calculer la part, dans le nombre total d'événements de pertes (2 500), que représentent les 9 événements dépassant 10 millions d'euros, ainsi que la part qu'ils représentent dans la sévérité totale (340 millions d'euros). Comparer ces deux parts aux chiffres de l'industrie cités par le cours (« 0,4 % du nombre d'occurrences [...] 66,6 % de la sévérité totale »). Calculer ensuite la perte moyenne par événement sur l'ensemble des 2 500 événements, puis la perte moyenne par

événement sur les 2 491 événements restants (hors les 9 événements extrêmes), et le rapport entre les deux moyennes. En quoi ce rapport illustre-t-il concrètement qu'« il n'y a pas de moyennes pertinentes en risque opérationnel » ?

- (c) Calculer le rapport entre le capital économique (99,9^e centile, 890 millions d'euros) et la médiane de la distribution simulée (300 millions d'euros), puis le rapport entre ce même capital économique et la sévérité effectivement observée cette année-là (340 millions d'euros). Pourquoi le cours recommande-t-il de communiquer au conseil ces centiles plutôt qu'un seul chiffre agrégé de perte moyenne ?
- (d) Si, comme cette année, la banque observe en moyenne 2 franchissements de seuil rouge par trimestre parmi ses KRI, calculer le nombre total d'escalades automatiques déclenchées sur l'année, et le rapport entre ce nombre d'escalades et le nombre de cycles de reporting trimestriels réguliers (4 par an). En quoi ce rapport illustre-t-il concrètement que « la communication du risque ne doit pas être purement périodique mais aussi événementielle » ?

Exercice 6 — Cartographie thermique agrégée : conversion en équivalent monétaire, pire cas plausible et perte de granularité, chiffrés

Une banque présente à son conseil d'administration une cartographie thermique combinant trois catégories de risque mesurées quantitativement à partir de pertes historiques ou de VaR opérationnelle, et trois catégories évaluées qualitativement par RCSA puis converties en équivalent monétaire à l'aide d'un barème interne validé par le second niveau de contrôle. Le barème associe à chaque niveau (1 à 5) une fréquence annuelle et une sévérité en millions d'euros :

Niveau	1	2	3	4	5
Fréquence annuelle	2 %	8 %	20 %	45 %	75 %
Sévérité (M€)	0,4	1,2	2,5	5,0	10,0

Les trois risques mesurés quantitativement affichent une perte annuelle moyenne (ou VaR) de : R1 Fraude externe = 4,2 M€; R2 Interruption informatique majeure = 2,8 M€; R3 Erreurs d'exécution/règlement = 1,5 M€. Les trois risques évalués qualitativement par RCSA ont reçu, en atelier, les niveaux suivants : R4 Conduite commerciale inappropriée – fréquence niveau 4, sévérité niveau 3; R5 Cyberattaque (hors interruption, ex. vol de données) – fréquence niveau 2, sévérité niveau 5; R6 Non-conformité réglementaire – fréquence niveau 3, sévérité niveau 4. L'équivalent monétaire d'un risque qualitatif est calculé comme le produit de sa fréquence annuelle par sa sévérité en euros.

- (a) Calculer l'équivalent monétaire de R4, R5 et R6. Classer les six risques (R1 à R6) par ordre décroissant de magnitude. Laquelle des trois méthodes d'agrégation des risques qualitatifs du cours est utilisée ici pour R4, R5 et R6 ?
- (b) Calculer le total agrégé des six équivalents monétaires, la part de R1 (le risque le plus élevé) dans ce total, ainsi que la part cumulée des trois risques mesurés quantitativement (R1+R2+R3) et celle des trois risques qualitatifs convertis (R4+R5+R6). Cette concentration entre les six catégories de la cartographie relève-t-elle du même phénomène statistique que la concentration des pertes individuelles décrite par les données ORX du cours (« 0,4 % du nombre d'occurrences [...] 66,6 % de la sévérité totale »), ou d'un phénomène distinct ? Justifier.
- (c) L'atelier RCSA a par ailleurs isolé, pour R5 (cyberattaque), un scénario de « pire cas plausible » distinct de son équivalent monétaire pondéré par la fréquence : une perte de 18,0 M€ en cas de matérialisation d'un incident cyber sévère unique. Calculer le rapport entre ce pire cas plausible et l'équivalent monétaire de R5 calculé au (a). Pourquoi le cours suggère-t-il que l'approche du pire cas plausible peut être plus informative que la conversion en équivalent monétaire pour un risque à « queue épaisse » comme le risque cyber, même si elle se prête moins bien à une vue unique et comparable sur une même cartographie ?
- (d) L'évaluation du niveau de sévérité 3 retenu pour R4 dans l'atelier RCSA résulte de huit scores individuels donnés indépendamment par les participants : 2, 3, 3, 4, 3, 2, 4, 3. Calculer la moyenne de ces huit scores (confirme-t-elle bien le niveau 3 utilisé au (a) ?), ainsi que l'écart-type de cette

série de scores. Qu'est-ce que le chiffre unique de 1,125 M€ affiché pour R4 sur la cartographie thermique du conseil dissimule de cette dispersion des jugements individuels, et en quoi est-ce un exemple concret de la « perte de granularité que le conseil accepte en échange de la lisibilité » évoquée par le cours ?